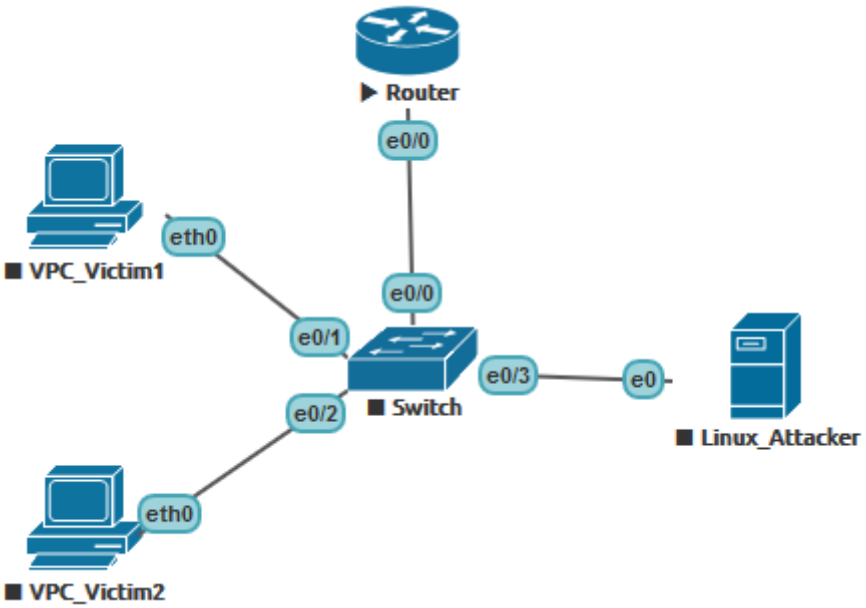
ARP MITM

GOAL

In computer networking, ARP spoofing, ARP cache poisoning, or ARP poison routing, is a technique by which an attacker sends (spoofed) Address Resolution Protocol (ARP) messages onto a local area network. Generally, the aim is to associate the attacker's MAC address with the IP address of another host, such as the default gateway, causing any traffic meant for that IP address to be sent to the attacker instead. ARP spoofing may allow an attacker to intercept data frames on a network, modify the traffic, or stop all traffic. Often the attack is used as an opening for other attacks, such as denial of service, a man in the middle, or session hijacking attacks. The attack can only be used on networks that use the Address Resolution Protocol, and is limited to local network segments.

The goal of this scenario is to demonstrate, how to intercept client's traffic by poisoning its ARP cache. Last but not least, DHCP Snooping together with Dynamic ARP Inspection will be deployed as an effective countermeasure against this type of attack.

TOPOLOGY



SCENARIO

1. Setup *Router* as DHCP server
2. Lease addresses for all clients
3. Perform ARP cache poisoning
4. Deploy Dynamic ARP Inspection
5. Verify DAI operation

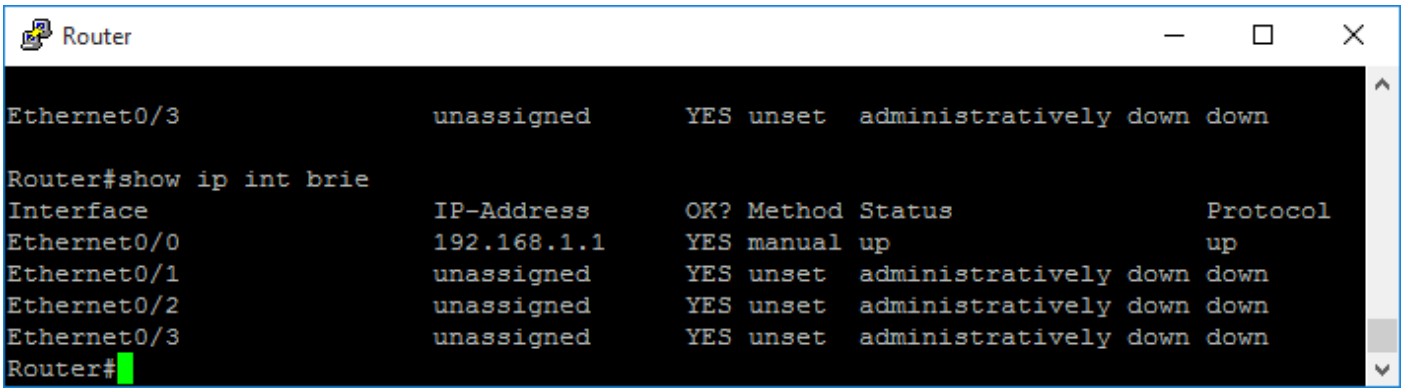
SETUP *ROUTER* AS DHCP SERVER

1. Enter global configuration

```
Router> enable
Router# configure terminal
```

2. Configure IP address on interface e0/0

```
Router(config)# interface e0/0
Router(config-if)# ip address 192.168.1.1 255.255.255.0
Router(config-if)# no shutdown
Router(config-if)# end
Router(config)# show ip interface brief
```



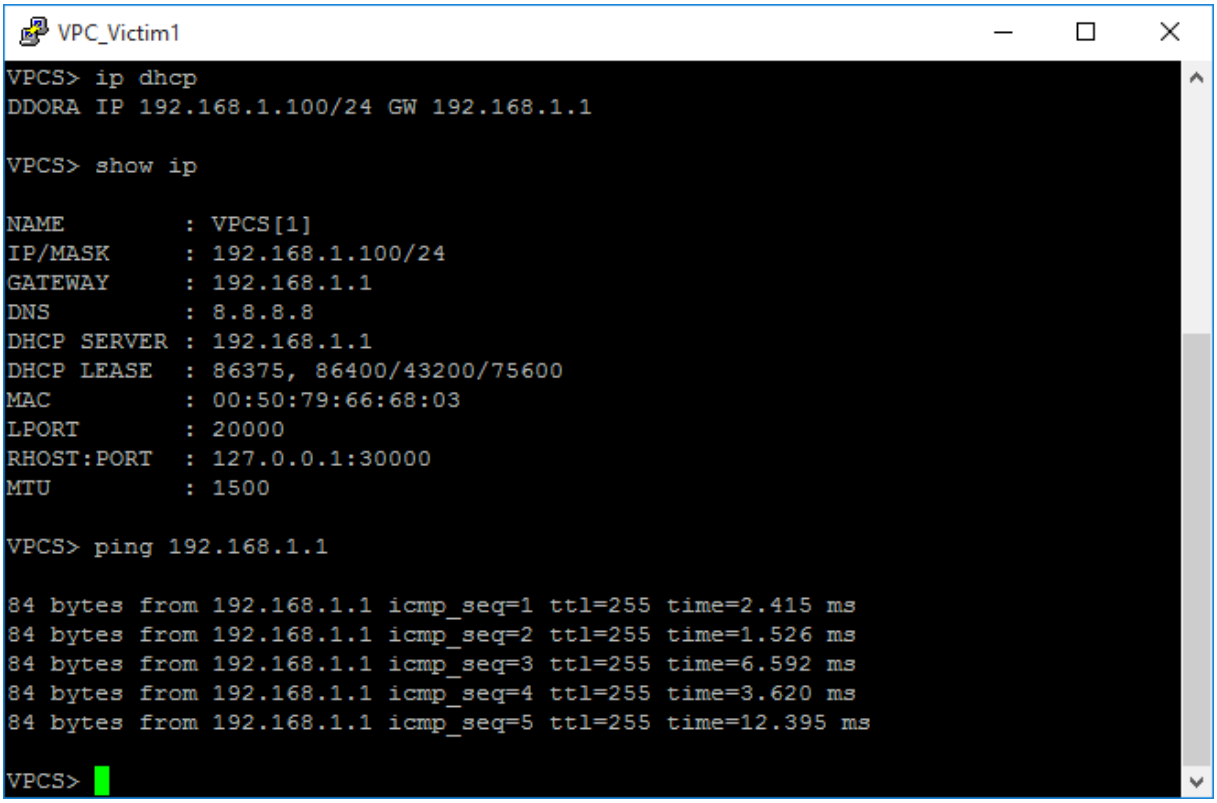
3. Create a DHCP Pool

```
Router# configure terminal
Router(config)# ip dhcp pool MYPOOL
Router(dhcp-config)# network 192.168.1.0 /24
Router(dhcp-config)# default-router 192.168.1.1
Router(dhcp-config)# dns-server 8.8.8.8
Router(dhcp-pool)# exit
Router(config)# ip dhcp exclude-address 192.168.1.1 192.168.1.99
```

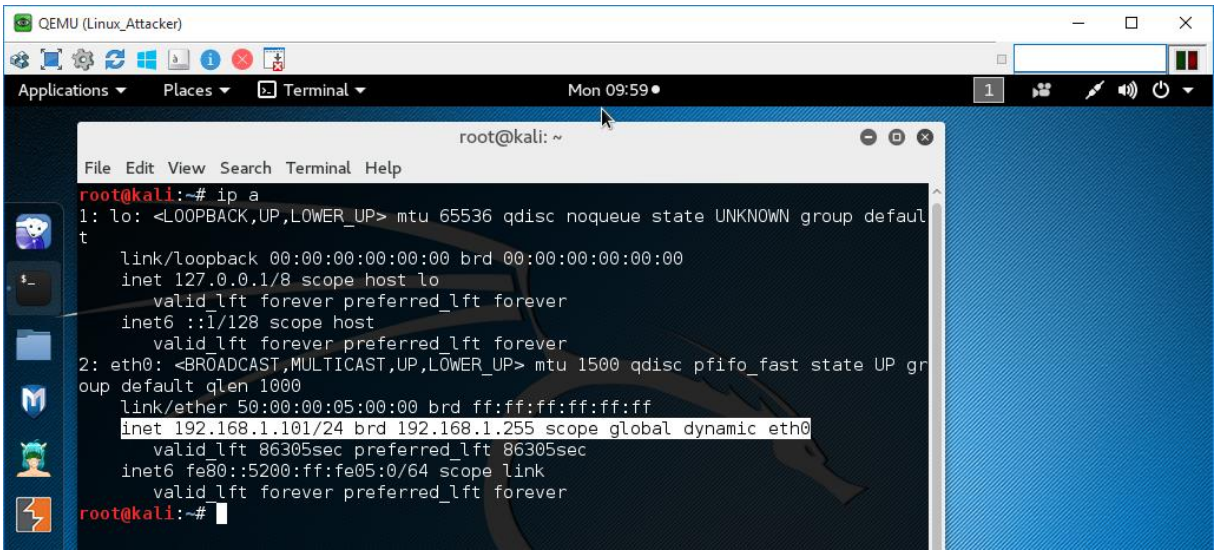
LEASE ADDRESSES FOR ALL CLIENTS

1. Ask for DHCP lease and verify connectivity to router on *VPC_Victim1* and *VPC_Victim2*

```
VPCS> ip dhcp
VPCS> show ip
VPCS> ping 192.168.1.1
```

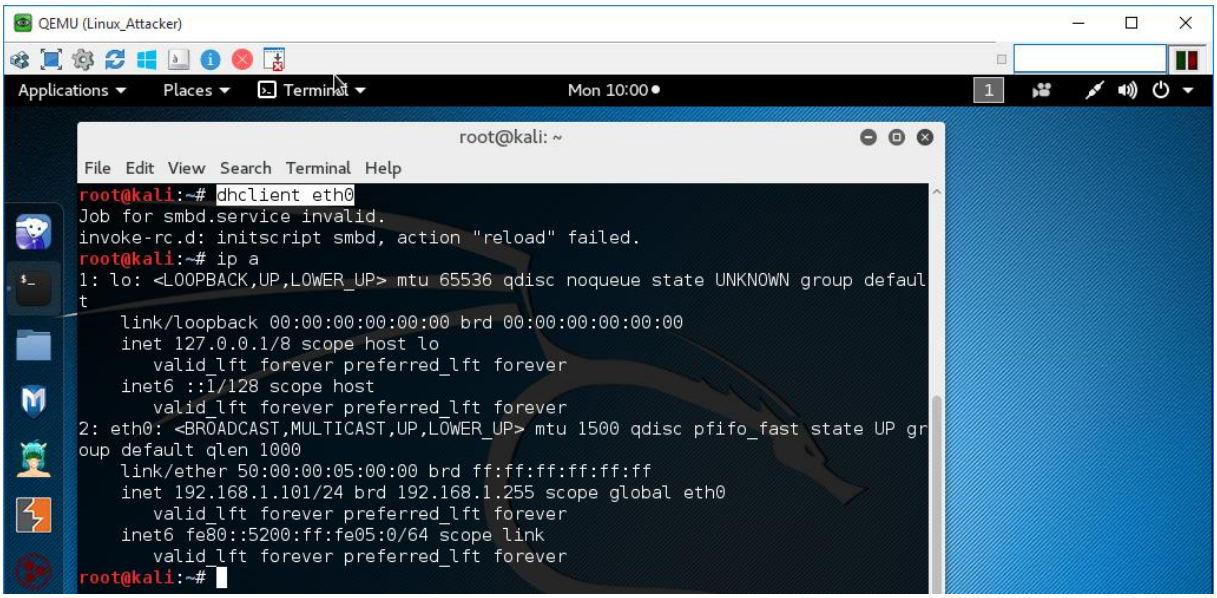


2. *Linux_Attacker* should receive address automatically during operating system startup.

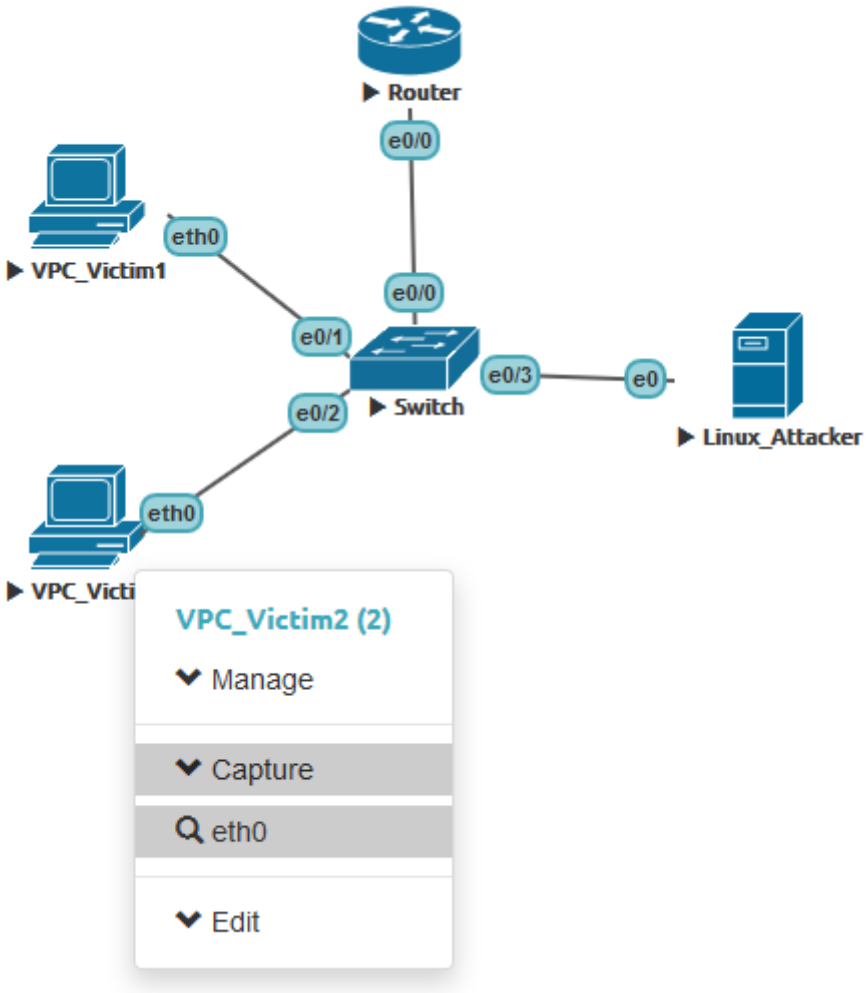


3. Otherwise, issue following command in terminal

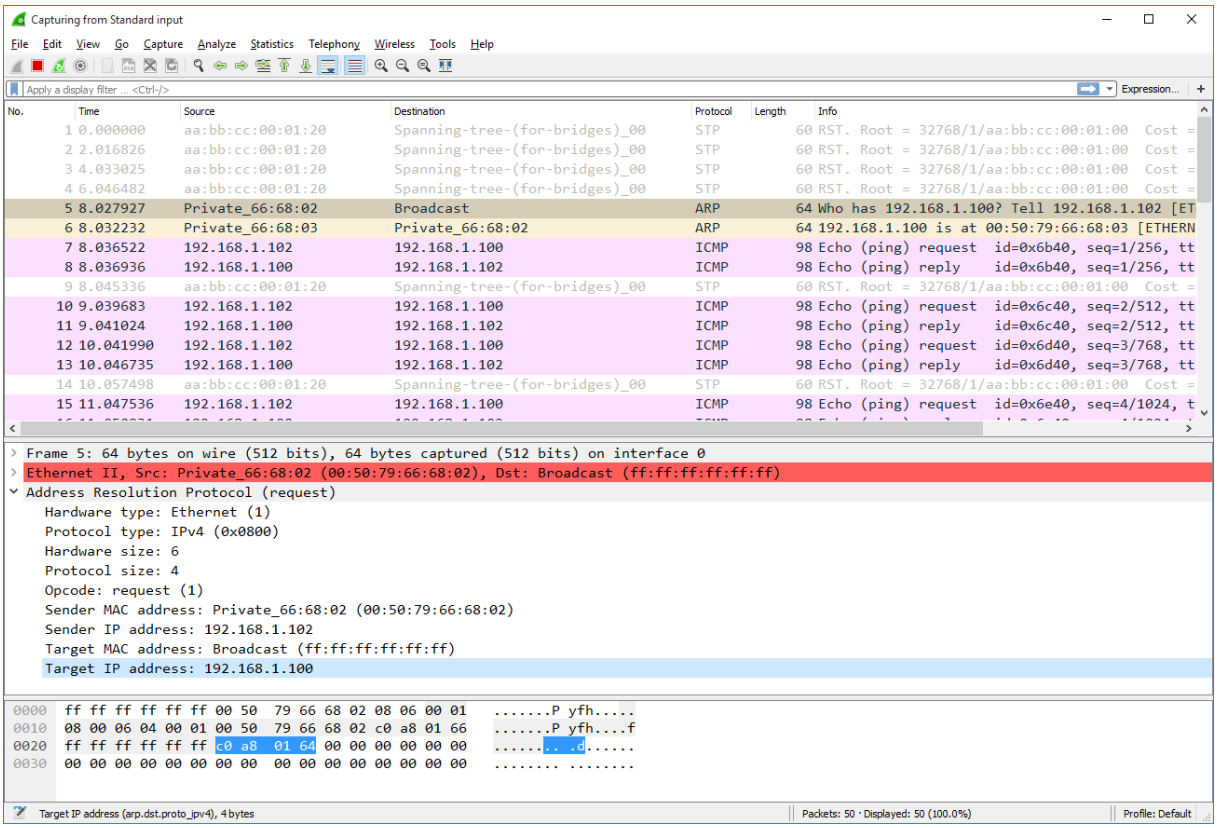
```
root@kali:~# dhclient eth0
```



4. Start capturing on *VPC_Victim2*'s interface eth0 by clicking on right mouse button in topology canvas

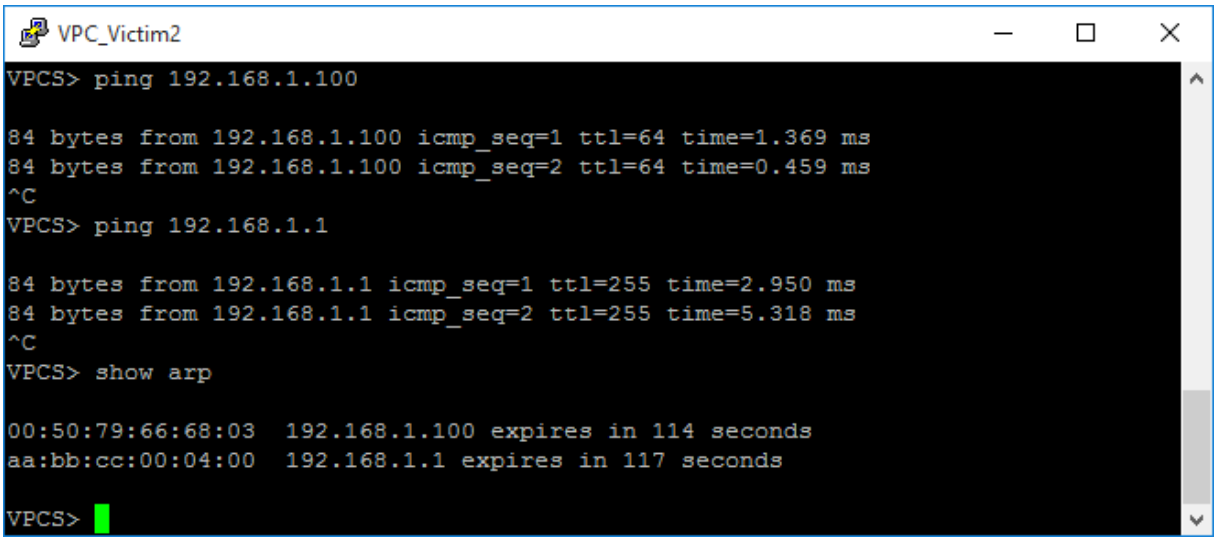


5. Ping between *VPC_Victim1*, *VPC_Victim2* and *Router*. Observe subsequent ARP and ICMP message exchange



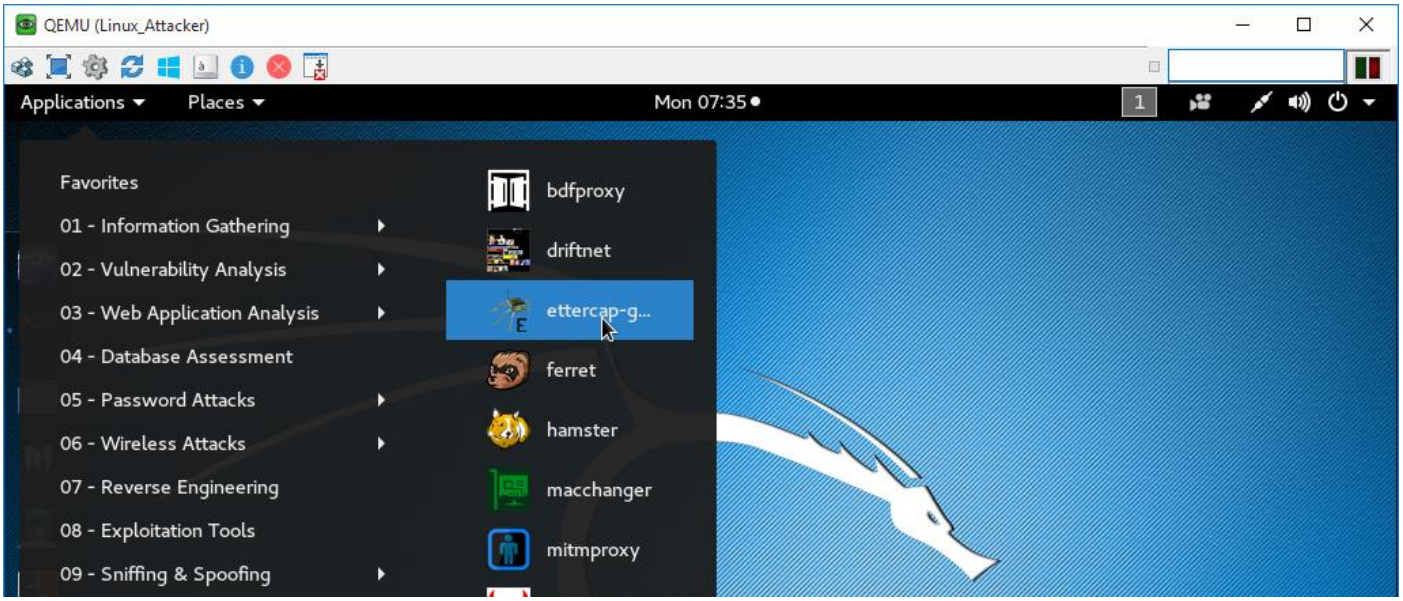
6. Check ARP cache on *VPC_Victim2*

```
VPCS> show arp
```

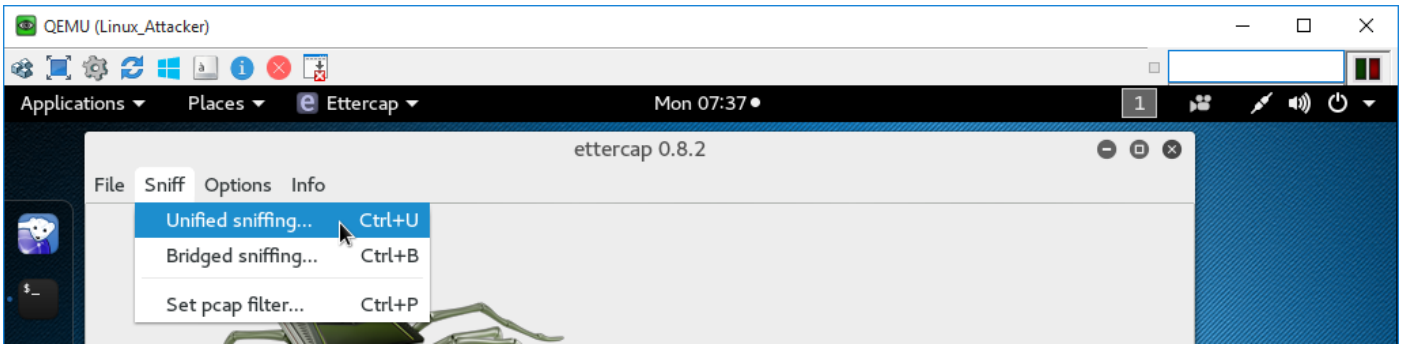


PERFORM ARP CACHE POISONING AND ARP MITM ATTACK

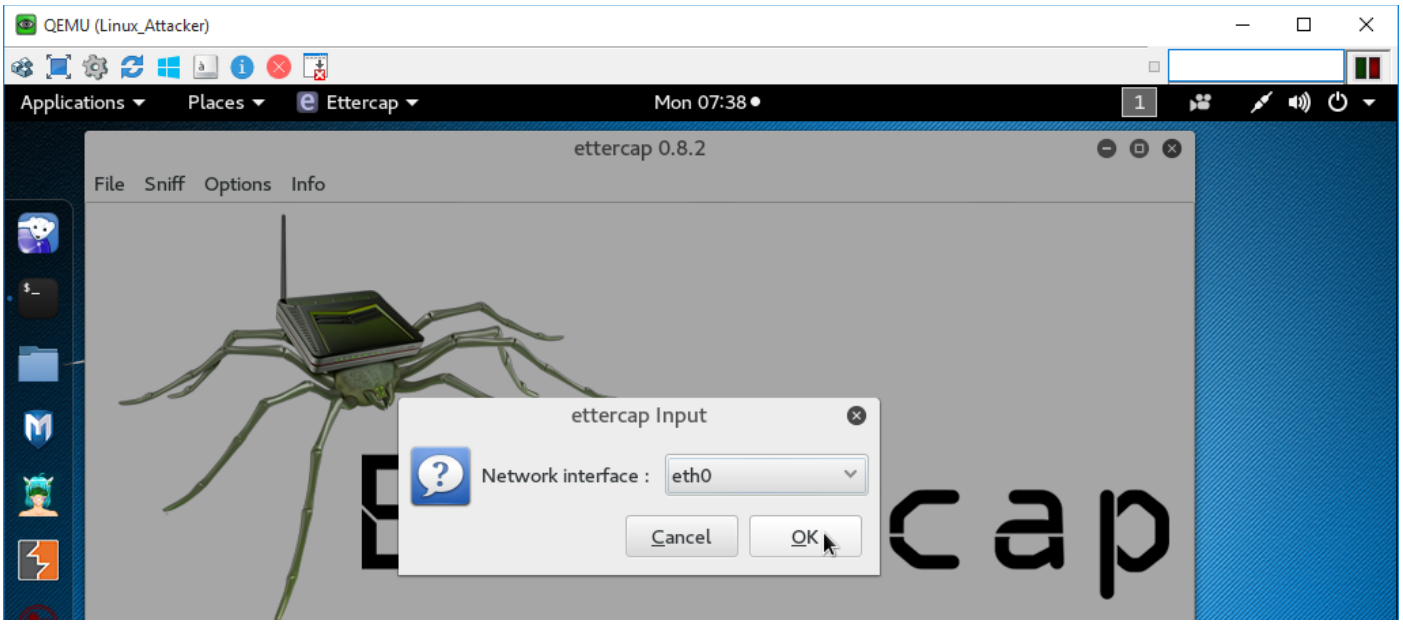
1. Launch Ettercap tool on *Linux_Attacker*, click on “Applications”, chose “09 – Sniffing & Spoofing“



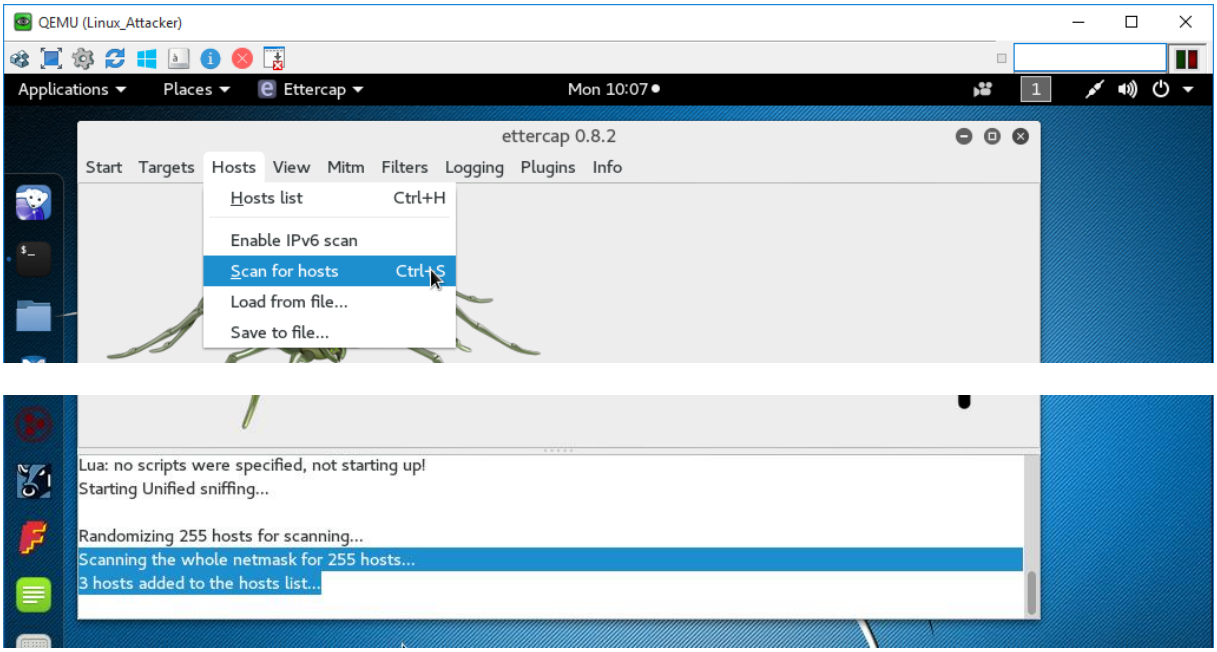
2. Initiate unified sniffing from network interface card by pressing Ctrl+U



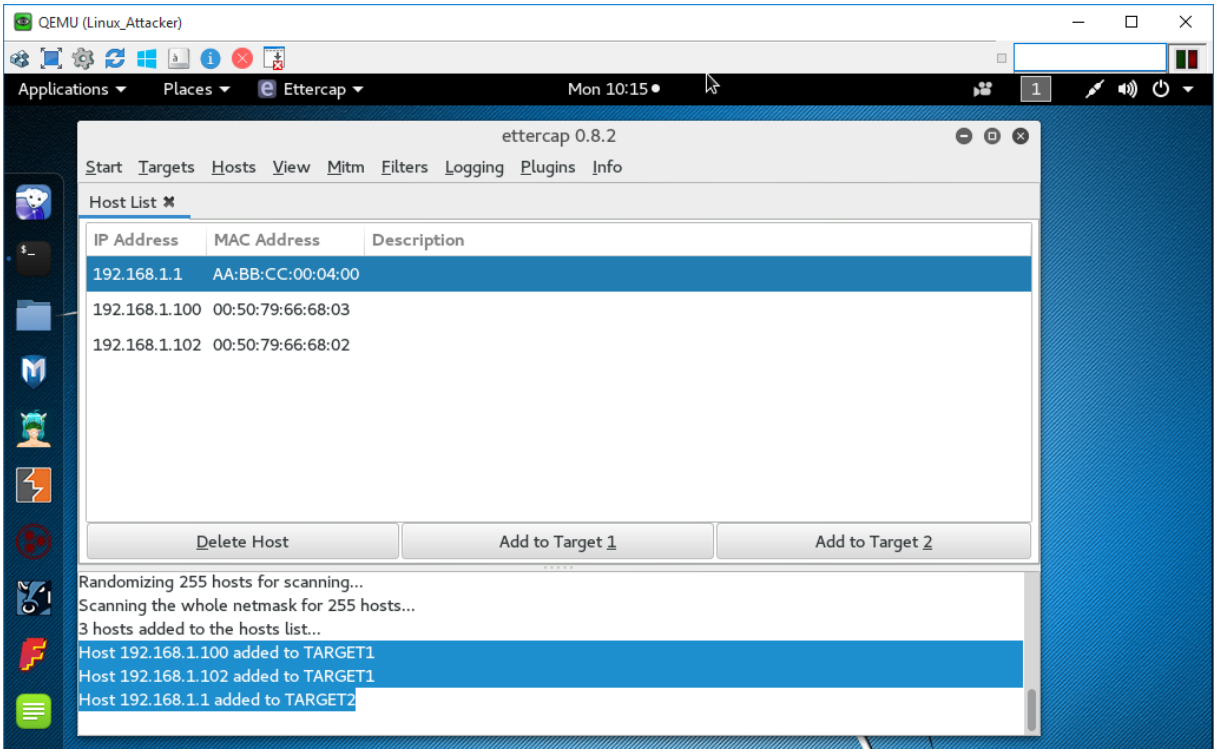
3. Pick eth0 interface and click “OK”



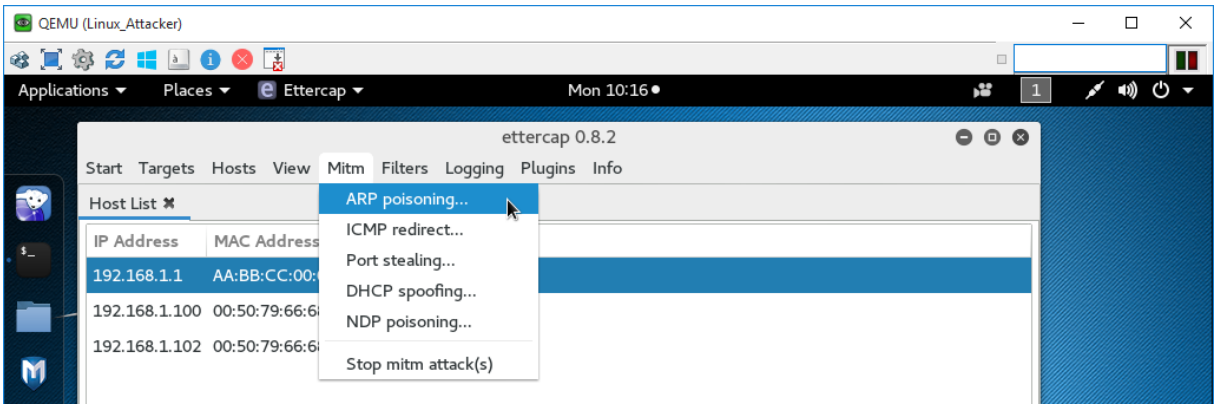
4. Scan network for present IPv4 devices by pressing Ctrl+S



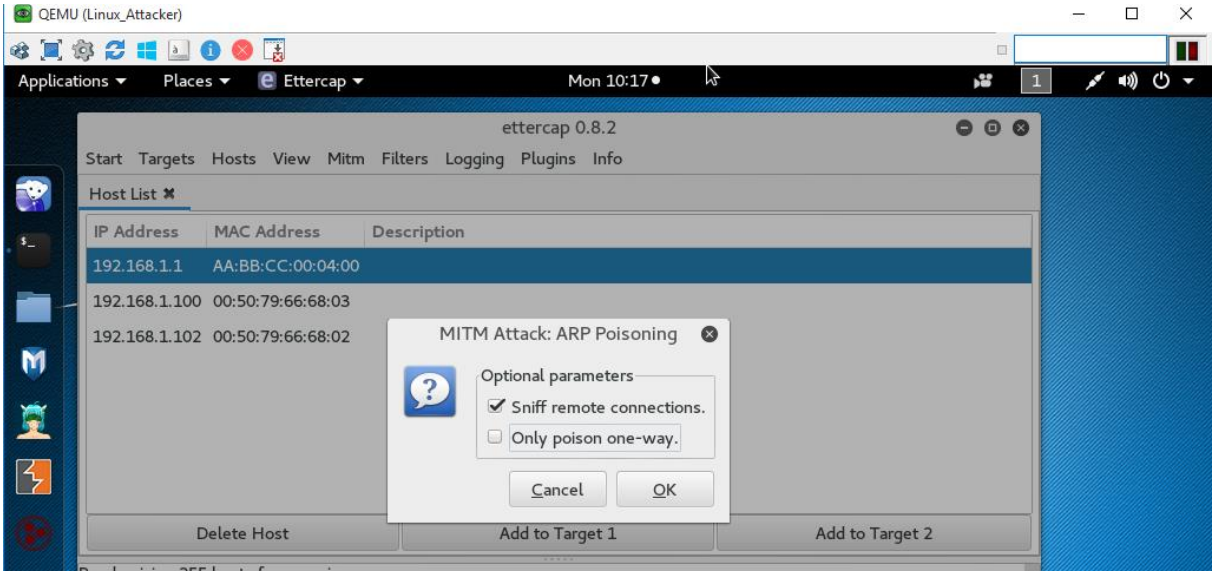
5. Display a host list, either by pressing Ctrl+H or using GUI option “Hosts -> Hosts list”. Mark targets by assigning *VPC_Victim1 and VPC_Victim2* to the group TARGET1 and Router to the group TARGET2



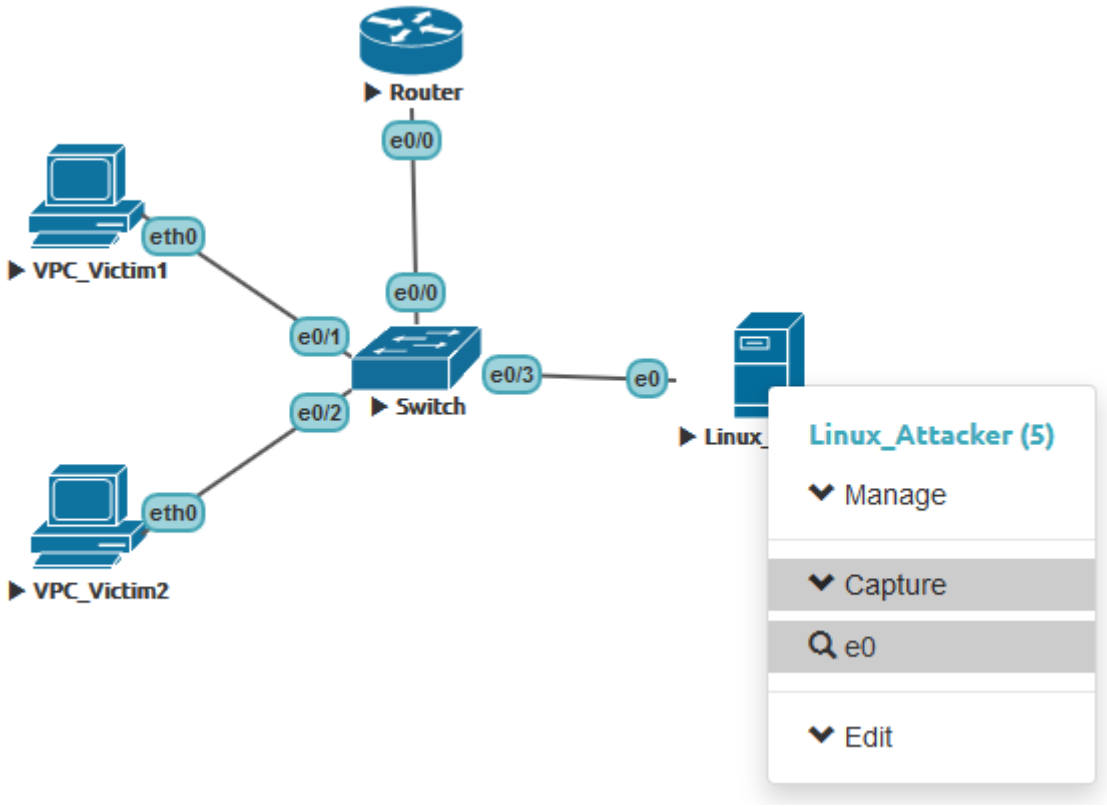
6. Initiate ARP poisoning by choosing “Mitm -> ARP poisoning” option



7. Select “Sniff remote connection” when you want to intercept also non-local communication and hit “OK”

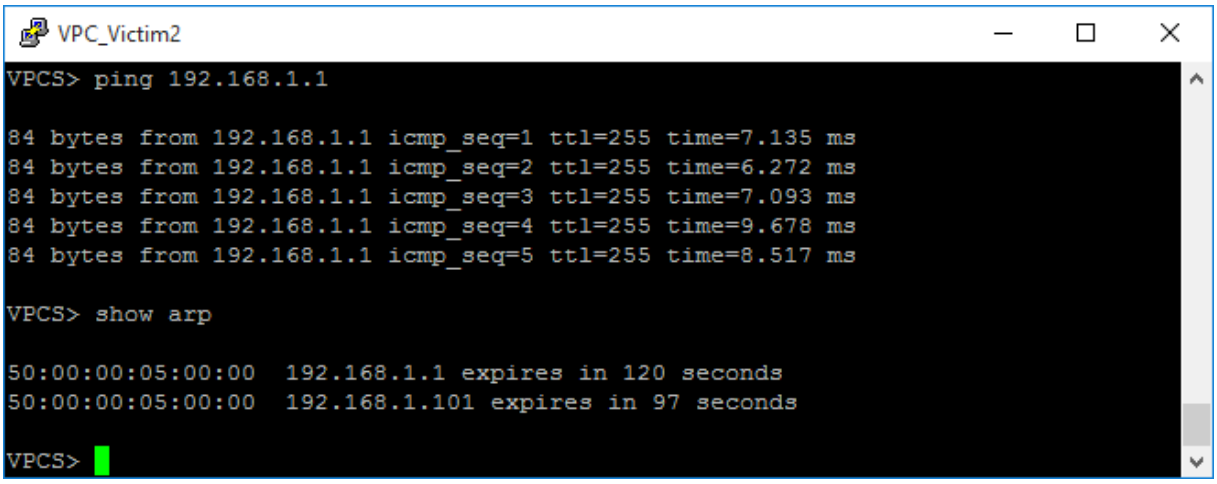


8. Start packet capturing on *Linux_Attacker*’s eth0 interface

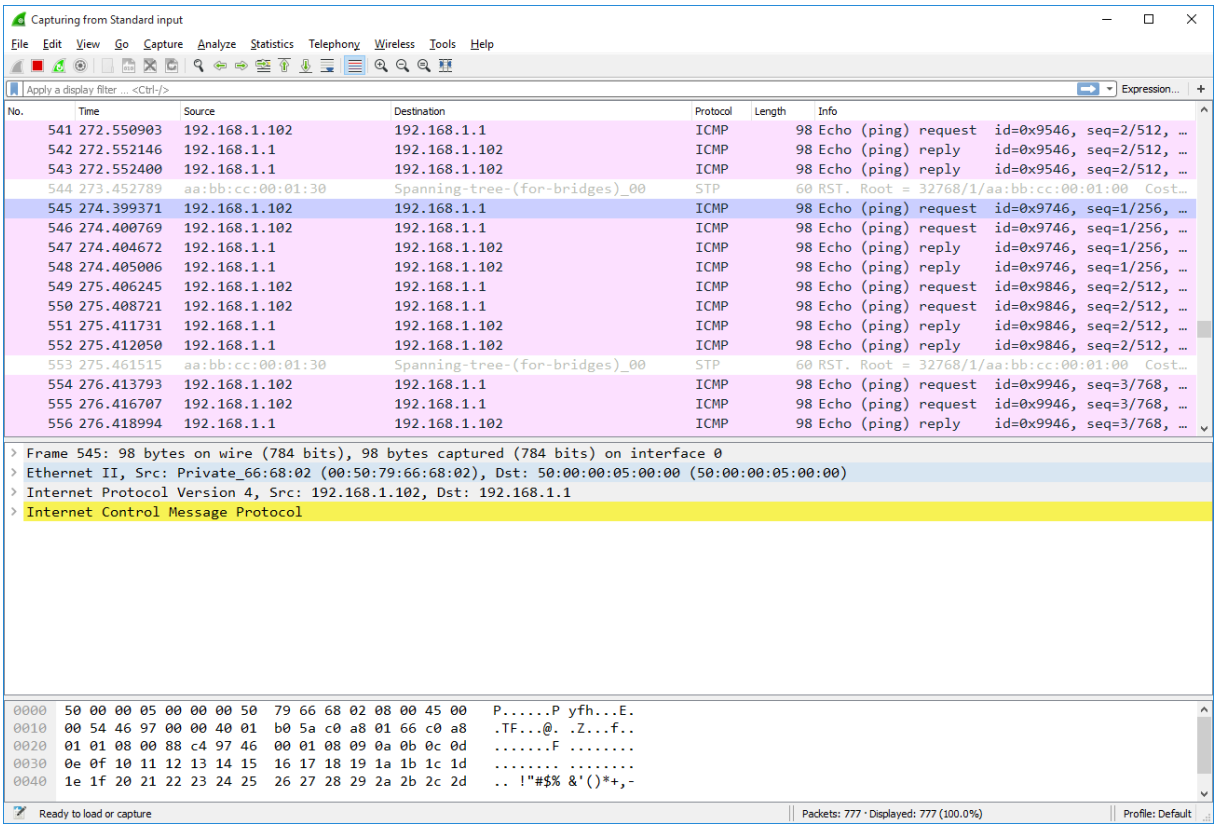


9. Try to ping from *VPC_Victim2* to *Router*. Observe how ARP cache has changed

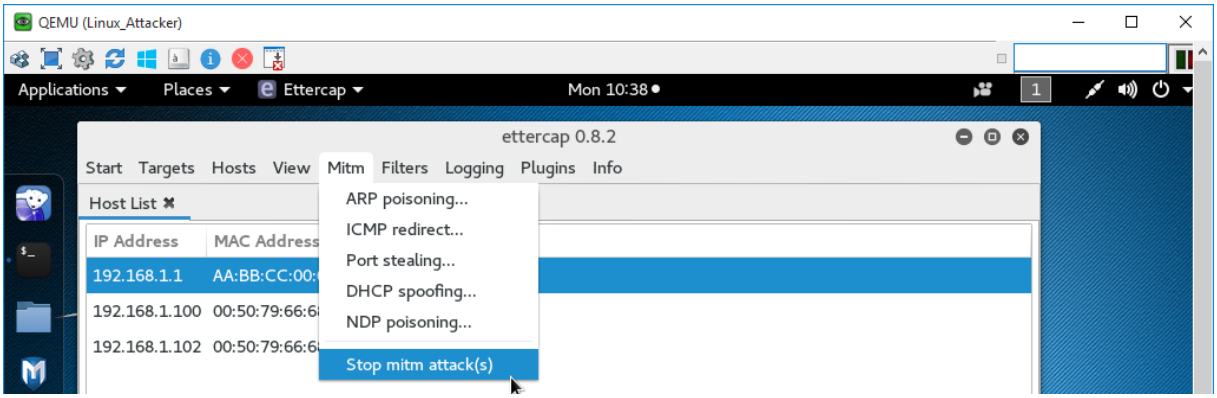
```
VPCS> ping 192.168.1.1
VPCS> show arp
```



10. You can see ICMP messages captured and intercepted by *Linux_Attacker*



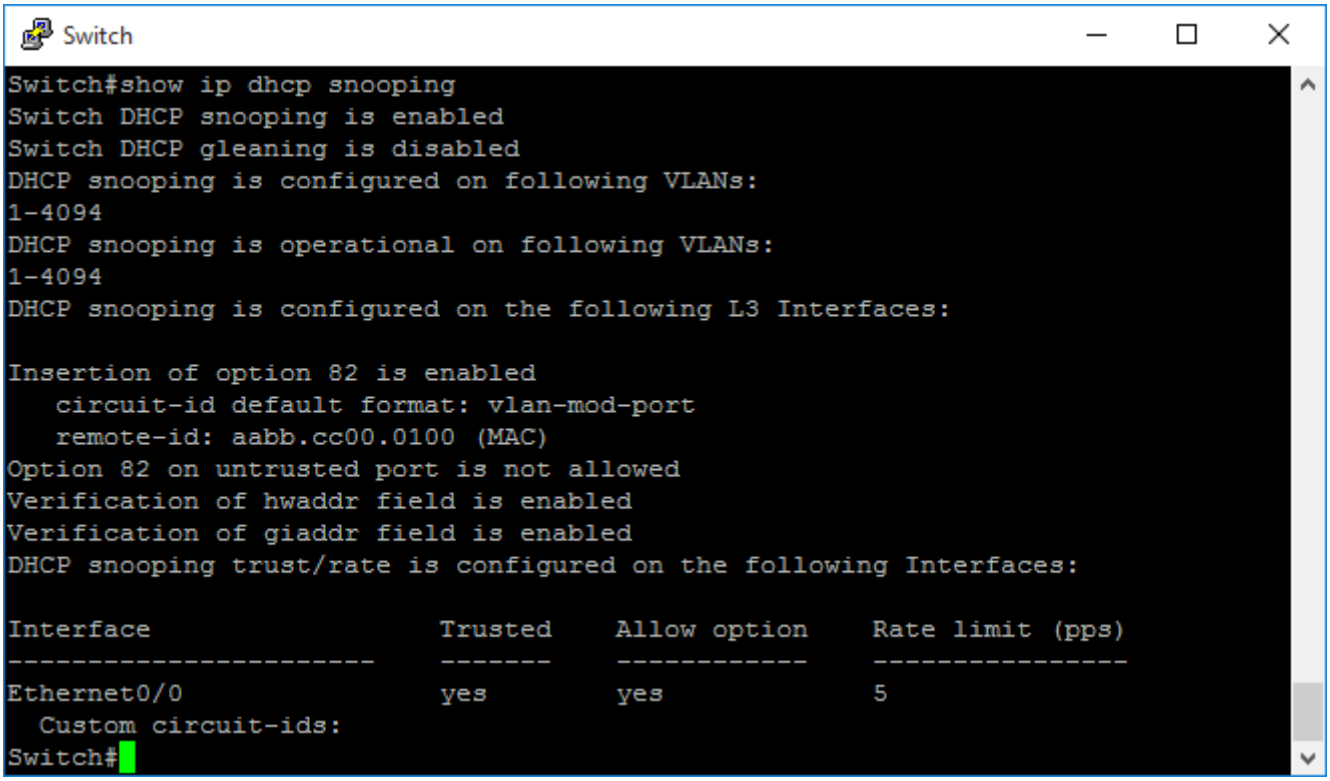
11. Stop the attack on *Linux_Attacker*



DEPLOY DYNAMIC ARP INSPECTION

1. Dynamic ARP Inspection (DAI) cooperates with DHCP Snooping, *Switch* leverages DHCP Snooping database for DAI functionality. Hence, configure DHCP Snooping first.
2. Configure DHCP Snooping for all VLANs on the switch (which is currently just default VLAN 1)

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 1
Switch(config)# interface e0/0
Switch(config-if)# ip dhcp snooping trust
Switch(config-if)# ip dhcp snooping limit rate 5
Switch(config)# end
Switch# show ip dhcp snooping
```



3. Configure DHCP Snooping on *Router*

```
Router# configure terminal
Router(config)# ip dhcp relay information trust-all
Router(config)# end
```

4. Renew IP addresses in order to populate DHCP Snooping database on *VPC_Victims*

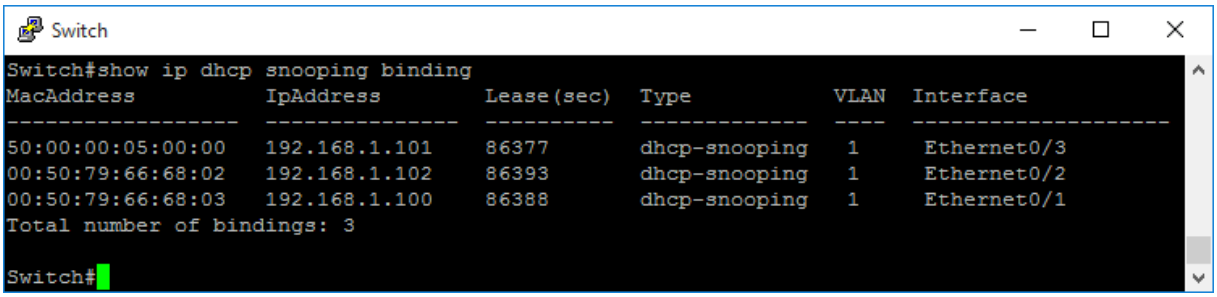
```
VPCS> ip dhcp
```

5. Renew IP address on Linux_Attacker

```
root@kali:~# dhclient eth0
```

6. Verify DHCP snooping database

```
Switch# show ip dhcp snooping binding
```



7. Configure Dynamic ARP Inspection on all VLANs (effectively just VLAN1 in this topology)

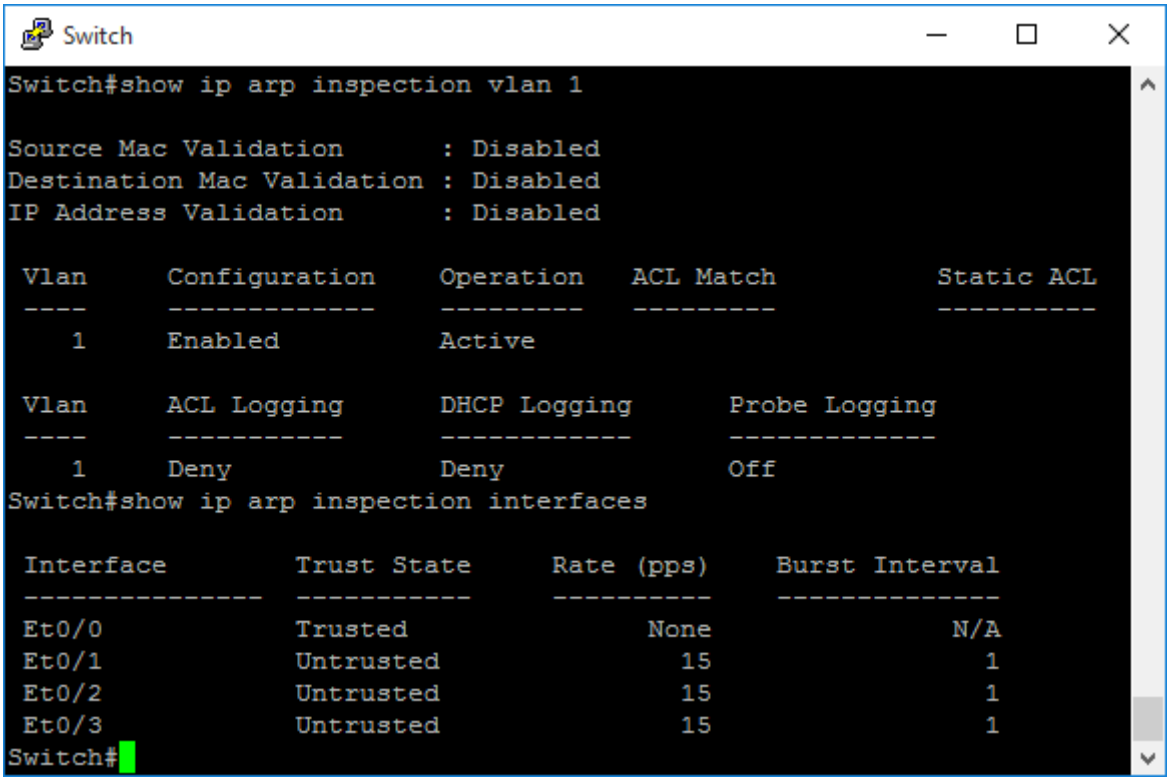
```
Switch(config)# ip arp inspection vlan 1
```

8. Mark interface e0/0 on *Switch* towards *Router* as trusted for DAI

```
Switch(config)# interface e0/0
Switch(config-if)# ip arp inspection trust
Switch(config-if)# end
```

9. Verify DAI configuration

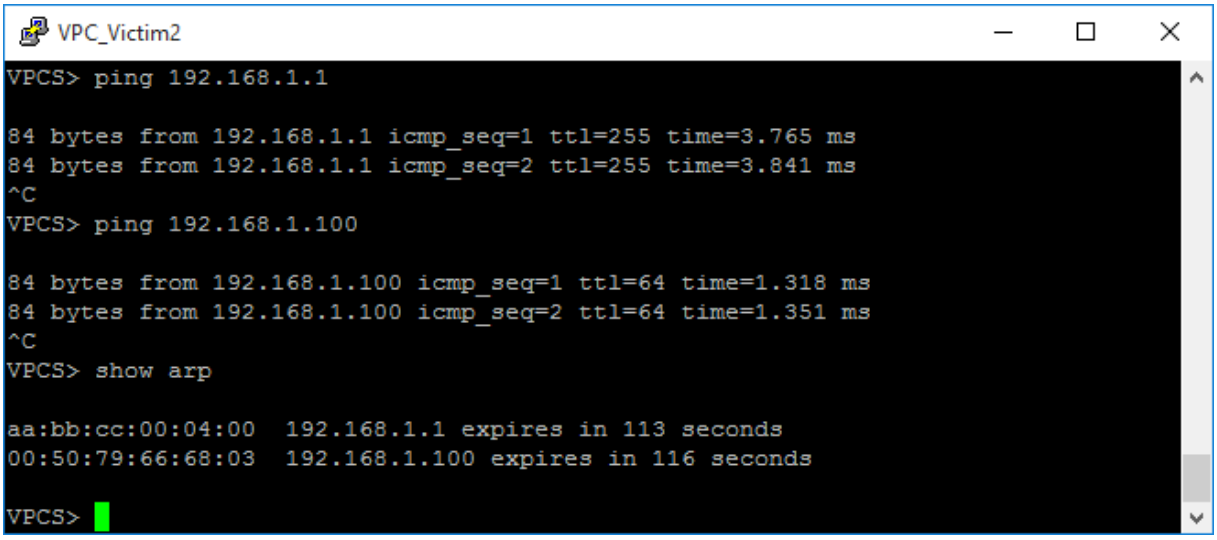
```
Switch# show ip arp inspection vlan 1
Switch# show ip arp inspection interfaces
```



VERIFY DYNAMIC ARP INSPECTION OPERATION

1. Ping between VPC_Victim1, VPC_Victim2 and Router. Observe ARP cache

```
VPCS> ping 192.168.1.1
VPCS> show arp
```



2. Dynamic ARP Inspection discards malicious traffic and notifies administrator by Syslog message

